

purdue-l3-site-operations brief

Purdue Site Operations (L3) — Cross-Vendor Threat & Detection Brief

Scope: Purdue Level 3 — "Site Operations" — is the OT domain controller tier where SCADA servers, engineering workstations (EWS), historians, asset/security management, power-infrastructure site servers, and substation industrial PCs reside. This brief cross-cuts Siemens (WinCC Unified, TIA Portal V18–V21), Rockwell Automation (FactoryTalk View SE, Studio 5000, RSLinx, FactoryTalk Services Platform, FactoryTalk Historian SE, FactoryTalk AssetCentre), Schneider Electric (EcoStruxure Power Operation, Citect SCADA, Control Expert, EcoStruxure Asset Advisor, PowerChute Network Shutdown), Honeywell (Experion PKS server + engineering tools, Uniformance PHD), Aveva (System Platform, Historian, Wonderware), OSIsoft PI (cross-vendor historian), SEL (acSELerator QuickSet, Compass, BaRT, ICS Studio + SEL-3355/3300 industrial PCs), and Eaton (Intelligent Power Manager, UPS Companion). L3 reaches L4 corporate IT only through the L3.5 DMZ, but pivots downward into L2 supervisory networks and L1 controllers via authenticated programming protocols (CIP, S7Comm, UMAS) and historian/OPC channels. Because L3 hosts authenticated sessions to controllers and centralized credentials to AssetCentre/Asset Advisor, compromise here is equivalent to "domain admin" of the plant.

Architecture grouping (organized by ROLE within this layer, not by vendor)

Class (role)	Products (cross-vendor)	Stack (RTOS/protocol/OS)	Catalog depth
SCADA Server	Siemens WinCC Unified, Rockwell FactoryTalk View SE Server, Schneider EcoStruxure Power Operation + Citect SCADA, Honeywell Experion PKS server, Aveva System Platform	Windows Server, OPC UA, FactoryTalk RNA, WinCC channels	Briefs exist (Siemens, Rockwell, Schneider, Honeywell)
Engineering Workstation (EWS)	Siemens TIA Portal V18/V19/V20/V21, Rockwell Studio 5000 + RSLinx Classic + FactoryTalk Linx, Schneider EcoStruxure Control Expert (Unity Pro), SEL acSELerator QuickSet/BaRT/Compass/ICS Studio, Honeywell Experion Engineering Tools	Windows 10/11, S7Comm/CIP/UMAS/SEL Fast Message	Briefs exist (Siemens, Rockwell, Schneider, SEL)

Class (role)	Products (cross-vendor)	Stack (RTOS/protocol/OS)	Catalog depth
Historian	Rockwell FactoryTalk Historian SE, OSIsoft PI (cross-vendor), Honeywell Uniformance PHD, Aveva Historian	Windows Server + SQL Server, OPC UA, PI Connectors	Research only (OSIsoft PI)
Asset / Security Management	Rockwell FactoryTalk AssetCentre, Schneider EcoStruxure Asset Advisor	Windows Server + SQL, agent-based collectors	Brief exists (Rockwell)
Power-Infra Site Server	Schneider PowerChute Network Shutdown, Schneider PowerChute Business, Eaton Intelligent Power Manager (IPM), Eaton UPS Companion	Windows/Linux, SNMP, vendor REST + NUT/SSH	Briefs exist (Schneider, Eaton)
Substation Industrial PC	SEL-3355-2 / SEL-3355 / SEL-3300 running substation HMI + acSElerator	Windows 10 IoT LTSC / Linux on SEL hardware, IEC 61850 MMS, DNP3, SEL Fast Message	Brief exists (SEL)

Group 1 — SCADA Server

Direct attack surface: Windows Server hosting OPC UA endpoints (TCP/4840), FactoryTalk RNA (TCP/1330–1332), WinCC OA/Unified channels (HTTPS + WebSocket), Citect display client TCP/2080, Experion server-to-station traffic, SMB/RPC for redundant pair sync, RDP/WinRM for engineer access.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2024-21915	9.0	Rockwell	FactoryTalk Services Platform	Privilege escalation in FactoryTalk Service Platform (ICSA-24-046-16)
CVE-2023-46290	8.1	Rockwell	FactoryTalk Services Platform (underpins FactoryTalk View SE)	Improper authentication — unauthenticated actor can obtain Windows OS user token via FTSP web service (ICSA-23-299-06)
OT:ICEFALL set	up to 9.8	Honeywell	Experion PKS / CDA protocol	Lack of encryption + weak authentication in CDA between Experion server and C300 controllers (Forescout OT:ICEFALL)
Vendor PSIRT	n/a	Siemens	SIMATIC WinCC Unified	Multiple input validation / XSS issues — see Siemens ProductCERT advisories for SIMATIC WinCC Unified

CVE	CVSS	Vendor	Product	Vector
Vendor PSIRT	n/a	Schneider	EcoStruxure / Citect SCADA / Citect Anywhere	Historical buffer-overflow / web-client RCE family — see Schneider Cybersecurity Notifications

Top attack vector (MITRE ATT&CK ICS): [T0832 Manipulation of View](#) — tampered SCADA tags + suppressed alarms while a parallel [T0831 Manipulation of Control](#) writes setpoints downstream.

Group 2 — Engineering Workstation (EWS)

Direct attack surface: Studio 5000 + RSLinx Classic (CIP over EtherNet/IP TCP/44818, UDP/2222), TIA Portal (S7Comm + S7CommPlus TCP/102), Control Expert (Modbus + UMAS TCP/502), acSElerator (SEL Fast Message + SSH), Experion Engineering Tools (HCI/CDA), local project file repositories on user profiles, FactoryTalk Linx as broker.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2022-1161	10.0	Rockwell	ControlLogix / CompactLogix / GuardLogix via Studio 5000	Stealthy logic injection — running bytecode differs from EWS view (Claroty Team82 , ICSA-22-090-05)
CVE-2021-22681	10.0	Rockwell	Studio 5000 Logix Designer	Hardcoded crypto key (ICSA-21-056-03)
CVE-2018-7841	9.8	Schneider	Modicon via Control Expert/UMAS	UMAS auth bypass — EWS-issued program download
CVE-2021-22779	8.1	Schneider	Modicon M340/M580 via Control Expert	UMAS authentication bypass
Evil PLC research	n/a	Rockwell / Siemens / Schneider	ControlLogix, TIA Portal, Control Expert	Weaponized PLC project file → RCE on EWS (Claroty Team82)
ICSA-23-131-08	up to 8.8	SEL	acSElerator QuickSet	Multiple deserialization + path traversal flaws

Top attack vector (MITRE ATT&CK ICS): [T0843 Program Download](#) — engineer's own signed session pushes attacker logic to L1; secondary [T0833 Modify Control Logic](#) and [T0858 Change](#)

Operating Mode (RUN→PROGRAM).

Group 3 — Historian

Direct attack surface: OSIsoft PI Server TCP/5450 (PI Data Archive), PI AF TCP/5457, FactoryTalk Historian SE on Windows + SQL Server, Uniformance PHD APIs, Aveva Historian SQL endpoints, OPC HDA/UA collectors that hold credentials to dozens of L2/L1 devices.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2020-12021	7.7	OSIsoft	PI Web API 2019	Stored XSS — authenticated attacker with PI Server write access executes arbitrary JS in the user's browser (ICSA-20-163-01)
CVE-2023-31274	7.5	Rockwell / AVEVA	FactoryTalk Historian SE (built on AVEVA PI Server)	Unauthenticated PI Message Subsystem memory-exhaustion DoS (ICSA-24-130-01)
AVEVA PI PSIRT	n/a	AVEVA / OSIsoft	PI Server / PI Data Archive	Historical authentication-bypass and information-disclosure family — see AVEVA Security Bulletins and ICSA-24-018-01 AVEVA PI Server
OT:ICEFALL set	up to 9.8	Honeywell	Experion / Uniformance ecosystem	Outdated cryptography and unauthenticated services (Forescout)

Top attack vector (MITRE ATT&CK ICS): [T0859 Valid Accounts](#) — historian service accounts have read access to most L2/L1 tags, ideal for [T0852 Screen Capture / collection](#)-style staging.

Group 4 — Asset / Security Management

Direct attack surface: AssetCentre disaster-recovery agents that hold *plaintext or weakly-encrypted* PLC credentials to every controlled L1 device; SQL Server backends; agent collectors with WMI/SMB to every EWS; Asset Advisor cloud connector outbound to Schneider services.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
CVE-2024-21915	9.0	Rockwell	FactoryTalk Services Platform (underpins	Privilege escalation (ICSA-24-046-16)

CVE	CVSS	Vendor	Product	Vector
			AssetCentre)	
CVE-2023-2071	9.8	Rockwell	FactoryTalk View Machine Edition (PanelView Plus)	Improper input validation → unauthenticated RCE via crafted CIP packets (ICSA-23-264-06)
AssetCentre PSIRT	n/a	Rockwell	FactoryTalk AssetCentre	Credential-store / disaster-recovery agent issues — see Rockwell Trust Center and ICSA-21-091-01
Schneider PSIRT	n/a	Schneider	EcoStruxure Asset Advisor	Vendor-managed cloud connector — see Schneider Cybersecurity Notifications

Top attack vector (MITRE ATT&CK ICS): [T0812 Default Credentials](#) + [T0866 Exploitation of Remote Services](#) — recover the AssetCentre credential vault, then use those credentials to T0843 every controller in scope.

Group 5 — Power-Infra Site Server

Direct attack surface: PowerChute Network Shutdown polling NMC2/NMC3 (TLStorm threat surface), Eaton IPM web UI (TCP/4679/4680), UPS Companion installer on Windows.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
ICSA-21-110-06	9.8	Eaton	Intelligent Power Manager <1.69	Unauthenticated eval() RCE on management server
CVE-2025-59887	7.8	Eaton	UPS Companion (Windows)	Installer DLL hijack — local privilege escalation
CVE-2022-22805	9.0	APC (Schneider)	NMC2/NMC3 (consumed by PowerChute)	TLStorm — TLS reassembly RCE (Armis)

Top attack vector (MITRE ATT&CK ICS): [T0813 Denial of Control](#) via coordinated UPS shutdown, or [T0884 Connection Proxy](#) using the management server as a Windows beachhead inside L3.

Group 6 — Substation Industrial PC

Direct attack surface: Windows 10 IoT LTSC on SEL-3355-2 with full HMI + acSElerator stack; IEC 61850 MMS (TCP/102) + DNP3 (TCP/20000) + SEL Fast Message to relays; engineer keyfobs/PIV; RTAC-adjacent.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
ICSA-23-131-08	up to 8.8	SEL	acSElerator QuickSet on SEL-3355	Multiple flaws — deserialization / path traversal
ICSA-23-194-02	up to 9.8	SEL	RTAC family adjacent to substation PC	Authentication + memory-corruption issues
Industroyer / Industroyer2	n/a	n/a (TTPs)	Substation HMI/MMS	Breaker manipulation via IEC 61850 MMS (Dragos)

Top attack vector (MITRE ATT&CK ICS): [T0855 Unauthorized Command Message](#) — substation PC issues MMS breaker-open commands, mirroring Industroyer.

Logging matrix (highest priority for this layer)

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	EWS Sysmon	Process create: Studio 5000 / TIA Portal / Control Expert / acSElerator launching outside business hours or by non-engineer SID	Stolen-credential program downloads, attacker-on-EWS	T0859 Valid Accounts
2	EWS Sysmon	Project file (.ACD, .ap18-21, .stu, .CXP, .rdb) opened from non-standard path / temp / network share	Evil PLC weaponized project staging	T0863 User Execution
3	SCADA server Windows Security	New Service / new scheduled task on WinCC / FT View SE / Experion server	Persistence on SCADA box	T0859 Valid Accounts
4	Network (Zeek/Suricata/Dragos/Claroty/Nozomi)	CIP/S7Comm/UMAS WRITE / STOP / DOWNLOAD originating from EWS subnet to L1 PLCs	Authenticated program download from L3 to L1	T0843 Program Download

#	Source	Event	What it catches	MITRE ATT&CK ICS
5	Network	RUN→PROGRAM mode change to controller	Mode change preceding logic tamper or CVE-2022-1161-style attacks	T0858 Change Operating Mode
6	FT AssetCentre / Asset Advisor audit	Bulk credential read / export / DR-archive download	Vault exfiltration → cross-controller takeover	T0812 Default Credentials
7	Historian (PI / FT Historian / PHD / Aveva)	New connector, new tag-pull credential, or off-hours bulk query	Reconnaissance + collection staging	T0852 Screen Capture / collection
8	OPC UA broker / FactoryTalk RNA	Anomalous client cert, unsigned client, lateral SCADA-to-SCADA channel	L3 lateral movement between SCADA servers	T0830 Adversary-in-the-Middle

Secondary: Siemens TIA Portal audit trail; Rockwell FactoryTalk Diagnostics; Schneider Control Expert audit log; Honeywell Experion event journal; SEL acSEerator audit trail; OSIsoft PI message log + PI Audit DB; Windows Event ID 4624/4672 on SCADA hosts; PowerShell ScriptBlock + AMSI on all EWS; OT-IDS alarm-rate anomalies; AppLocker/WDAC deny events for unsigned binaries in `C:\Program Files (x86)\Rockwell Software\` and `C:\Program Files\Siemens\Automation\`.

Cross-layer pivots

- L4 → L3.5 → L3 SCADA server:** phished corporate user pivots through jump host in L3.5 DMZ, lands on a domain-joined SCADA server (WinCC Unified / FactoryTalk View SE) using stolen valid accounts ([T0822 External Remote Services](#)), then escalates via CVE-2024-21915 on FactoryTalk Services Platform.
- L3 EWS → L1 PLC (the Stuxnet / Evil PLC path):** attacker on Studio 5000 / TIA Portal / Control Expert uses the engineer's already-authenticated CIP/S7Comm/UMAS session to push tampered logic ([T0843](#) + [T0833](#)). Stealth amplified by CVE-2022-1161 (online view diverges from running bytecode). Reverse direction is Claroty's Evil PLC — a poisoned PLC project compromises the EWS on next upload.
- L3 SCADA → L2 supervisory / L1 via OPC UA + FactoryTalk RNA:** compromised SCADA server abuses already-trusted OPC UA / RNA / WinCC channels to write setpoints across the

supervisory bus ([T0831 Manipulation of Control](#), [T0836 Modify Parameter](#)) while suppressing alarms on the operator HMI ([T0832 Manipulation of View](#)).

4. **L3 management** → **SIS (the TRITON pattern)**: co-resident management agent (AssetCentre, Asset Advisor, Experion engineering tools) reaches a Triconex Tricon or other SIS controller and tampers with safety firmware ([T0857 System Firmware](#), [T0879 Damage to Property](#)) — the XENOTIME TTP set ([Dragos](#)).
5. **L3.5 UPS/NMC** → **L3 SCADA**: TLStorm-class compromise of an APC NMC managed by PowerChute, or Eaton IPM RCE (ICSA-21-110-06), gives the attacker a Windows beachhead inside the L3 broadcast domain — used as [T0884 Connection Proxy](#) to reach SCADA without crossing the L3.5 firewall again.

Sources

- [CISA ICSA-24-046-16](#) — Rockwell FactoryTalk Service Platform (CVE-2024-21915)
- [CISA ICSA-23-299-06](#) — Rockwell FactoryTalk Services Platform (CVE-2023-46290)
- [CISA ICSA-22-090-05](#) — Rockwell Logix Controllers (CVE-2022-1161)
- [CISA ICSA-21-056-03](#) — Rockwell Studio 5000 (CVE-2021-22681)
- [CISA ICSA-21-091-01](#) — Rockwell FactoryTalk AssetCentre
- [CISA ICSA-23-264-06](#) — Rockwell FactoryTalk View Machine Edition (CVE-2023-2071)
- [CISA ICSA-23-131-08](#) — SEL acSELeRator QuickSet
- [CISA ICSA-23-194-02](#) — SEL RTAC
- [CISA ICSA-21-110-06](#) — Eaton Intelligent Power Manager
- [CISA ICSA-24-130-01](#) — Rockwell FactoryTalk Historian SE (CVE-2023-31274)
- [CISA ICSA-24-018-01](#) — AVEVA PI Server
- [CISA ICSA-20-163-01](#) — OSIsoft PI Web API (CVE-2020-12021)
- [CISA AA24-038A](#) — PRC State-Sponsored Actors (Volt Typhoon)
- [NVD CVE-2022-1161](#) — Rockwell Logix stealthy logic injection
- [NVD CVE-2018-7841](#) — Schneider UMAS
- [NVD CVE-2021-22779](#) — Schneider Modicon UMAS
- [NVD CVE-2023-46290](#) — Rockwell FactoryTalk Services Platform
- [NVD CVE-2025-59887](#) — Eaton UPS Companion DLL hijack
- [Claroty Team82](#) — Evil PLC Attack
- [Claroty Team82](#) — Hiding Code on Rockwell PLCs (CVE-2022-1161)
- [Armis](#) — TLStorm research
- [Forescout](#) — OT:ICEFALL
- [Dragos](#) — Industroyer2 / INCONTROLLER analysis
- [Dragos](#) — XENOTIME threat group
- [Siemens ProductCERT](#)
- [Rockwell Automation Trust Center](#)
- [Schneider Electric Cybersecurity Notifications](#)
- [Honeywell Product Security](#)

- [AVEVA Cyber Security Updates](#)
- [SEL Security Advisories](#)
- [MITRE ATT&CK for ICS — techniques index](#)
- [ISA/IEC 62443 — Industrial automation and control systems security](#)
- [Purdue Enterprise Reference Architecture / ISA-95](#)